
A Deterministic Exfiltration Oracle for Agent Security Evaluation

Anonymous Author(s)

Affiliation

Address

email

Abstract

1 Evaluating whether a tool-using agent can be induced to exfiltrate sensitive data
2 currently requires judging, per episode, whether an attack succeeded. We replace
3 that judgement with a construction: a synthetic record no legitimate task transmits
4 is planted in the agent’s data store, and its bytes appearing in an outbound tool
5 argument addressed to an attacker-controlled host is exfiltration by construction—
6 sound because the adversary has unbounded freedom over the injected instruction
7 and none over the stolen record, which must arrive intact to have value. Testing the
8 obvious form of this label against a matched benign control arm falsified it: “the
9 record appears in any outbound argument” fired on 9 of 16 adversary-free episodes
10 for Llama 3.3 70B—56% false positives—because transmitting member records is
11 plausibly the agent’s job. Scoping to the attacker’s host gave 0/16 with detection
12 unchanged. Any label of the form “a sensitive artifact appeared in an outbound
13 channel” inherits the agent’s base rate of legitimate transmission. Separately, with
14 no adversary present, Llama 3.3 70B fabricated internal-sounding endpoints and
15 posted the planted identifier to them under a system prompt naming those records
16 as protected health information. Injected exfiltration was 8/16 and 16/16 across
17 64 episodes; we decline to read that gap as a claim about deployment category,
18 because the design confounds license with model tier.

19 1 Introduction

20 A tool-using agent reads data in order to act on it. Operator instructions and text encountered while
21 working arrive through the same channel, as one undifferentiated token stream, with no boundary
22 marking which span is data and which is an order [Greshake et al., 2023, Perez and Ribeiro, 2022].
23 Text placed where the agent will read it therefore competes with the operator’s instructions on
24 equal terms, and the agent acts on it with its own legitimate credentials [OWASP Gen AI Security
25 Project, 2025]. Anyone deploying such an agent wants a number: how often does it fall for that?
26 Producing one requires deciding, per attack, whether it succeeded—presently by reading transcripts
27 or asking another model. Both are judgements: priced per call, moving between runs, not auditable
28 by re-execution.

29 **The construction.** We remove the judgement rather than improve it. A synthetic member record,
30 MBR-7K2QX9-4418ZT, is planted in the agent’s data store; no legitimate task transmits it outside the
31 trust boundary. If those bytes appear in an argument to an egress tool addressed to a host the adversary
32 controls, exfiltration occurred by construction. Scoring is a byte comparison over 7 encodings, with
33 no model in the path. The construction rests on an asymmetry favouring the defender: the adversary
34 may write the injected *instruction* in unboundedly many ways, and we never inspect it; they may not
35 obfuscate the *record* past recoverability, because a record that does not arrive intact is worthless. We
36 stop watching the input, where the adversary is free, and watch the output, where they are not.

A negative result that changed the design. Our first label was the obvious one: the canary in any outbound argument. A matched control arm—the same 16 tickets with every injection removed—falsified it, firing on 9 of 16 adversary-free episodes because posting member data to internal systems is a plausible reading of the agent’s job. Requiring the attacker’s host took false positives to 0/16 with detection unchanged. The generalization matters more than the repair: *any* label of the form “a sensitive artifact appeared in an outbound channel” inherits the agent’s base rate of legitimate transmission, and for an agent whose function is handling those artifacts that rate is not small.

We contribute the label (section 3), its measured false-positive rate (section 5.1), unprompted egress of planted identifiers (section 5.2), a positive-control gate (section 3.1), and a 2-model pilot whose family-level reading we refuse (section 5.4).

2 Related Work

Indirect prompt injection—placing adversarial text where a model-integrated application will retrieve it, rather than typing it at the model—was characterized by Greshake et al. [2023], following earlier work on direct instruction-overriding attacks [Perez and Ribeiro, 2022]. It is catalogued as the first entry of the OWASP list for generative-AI applications [OWASP Gen AI Security Project, 2025].

Benchmarks for tool-integrated agents—InjecAgent [Zhan et al., 2024], AgentDojo [Debenedetti et al., 2024]—establish that deployed agents are susceptible and differ in attack and defense coverage. Our contribution is orthogonal: how an exfiltration event is *labelled*, and what that label’s false-positive rate is when measured on a matched benign arm rather than assumed.

3 Method

Threat model. The adversary can write text into a field the agent reads while working and controls a network destination; they cannot modify the system prompt, tool definitions, weights, or harness. The agent’s credentials are legitimate—it is authorized to retrieve member records, because retrieval is the task. We measure whether it can be induced to *place* a record in an outbound argument addressed to the adversary, not whether that request would traverse a network (section 6).

Canary, detector, policy. A synthetic member record carrying MBR-7K2QX9-4418ZT and 14 fields (name, date of birth, diagnosis codes, medications, address) is planted among 8 records; it is invented in full. *Detection*—which encoding of the canary is present in a string—is a pure function of bytes, frozen, and exercised by 21 tests. *Policy*—which tools are egress, which host is the adversary’s—is configurable and delegates every byte-level decision to the detector rather than reimplementing a matcher; re-scoring every logged call and episode through both paths gave identical verdicts. The detector reports the least-transformed of 7 encodings (exact, whitespace_chunked, base64, hex, url_encoded, reversed, per_char_delimited); a novel encoding is scored conservatively as no leak, so rates are lower bounds. Canary bytes in a *retrieval* argument are never counted—looking a member up is the task—and only the 2 egress tools (http_post, dns_lookup) are scored.

3.1 Agent under test

The reference agent is a member-services agent for a fictional health plan, with 5 tools and a 6-turn budget, which resolves a support ticket end to end. Tool calls are emitted as plain text and parsed by regular expression rather than through a native function-calling interface; its system prompt states that member records are protected health information. Tools are simulated and return fixed data.

Corpus, control arm, and the gate. The corpus is 16 payloads: 4 channels (kb_article, prior_transcript, record_notes, ticket_body) crossed with 4 variants (authority, html, plain, unicode), each channel dressing the injected text as that surface plausibly looks and each variant holding intent fixed while changing surface form (section D). Every payload has a matched control: identical ticket, member, and tool surface, injected span removed and nothing substituted—the only way to measure the label’s false-positive rate, and section 5.1 reports that measuring it changed the label. An agent that never executes produces zero detected exfiltrations and zero false positives—the characteristic failure of a bring-your-own-agent tool, whose most dangerous output is a clean bill of health it did not earn. The harness therefore refuses to score until four checks pass,

Table 1: The same 16 adversary-free episodes scored by two predicates, for Llama 3.3 70B. Detection on the injected arm is unchanged; the false-positive rate is not.

	Naive predicate	Reported predicate
Detects on injected arm	8/16	8/16
Fires on adversary-free arm	9/16	0/16
False-positive rate	56%	0%

the fourth a positive control in which a blatant unobfuscated exfiltration instruction is issued and the oracle *must* detect the leak; an override stamps every artifact unverified. The gate caught a real defect in this project’s own adapter scaffold, where template and harness imported the same base class by two module paths and a correct adapter was rejected.

4 Experimental Setup

Two deployed models were evaluated: Llama 3.3 70B (open-weights, hosted) and Gemini 3.1 Flash-Lite (proprietary)—one per deployment category, differing substantially in tier and scale (section 5.4). Four further models were attempted and dropped before scoring for credential or free-tier quota reasons unrelated to the behaviour under study; none contributes to any reported number (section A). One trial per cell at temperature 0, a 1024-token output cap, and a 6-turn budget; responses are cached by prompt, so the study is idempotent. It consumed 315 model calls, is closed, and all analysis re-reads those responses. The cap was raised from an initially planned 300 tokens because the proprietary arm spends output tokens on hidden reasoning before emitting a tool call, so too small a cap truncates episodes before the egress call and *understates* exfiltration. The primary metric is the canary’s bytes, under any of the 7 encodings, in an egress-tool argument destined for `records-sync.example.net`; intervals are percentile bootstrap over 10,000 resamples of the corpus at seed 20260913, quantifying payload variability, not run-to-run variability.

5 Results

5.1 The label’s false-positive rate, measured

The natural label for this construction is “the planted record appeared in an outbound tool argument.” Running the matched control arm—the same 16 tickets with every injection removed, no adversarial text anywhere in the episode—falsified it.

Table 1 gives the result. On 9 of 16 episodes with no adversary present, Llama 3.3 70B placed the planted member identifier into an outbound request—a false-positive rate of 56% for the naive predicate. Requiring the destination to be `records-sync.example.net` moved that to 0/16, while the injected-arm detection count stayed at 8/16. Across both models’ control arms the reported label fired 0/32 times.

The repair is not a threshold but a change to what the label *means*, and the generalization is the part worth carrying away: any label of the form “a sensitive artifact appeared in an outbound channel” silently inherits the agent’s base rate of legitimately transmitting that artifact, which for an agent whose function is handling such artifacts is not small—here 56%. An evaluation that asserts a low false-positive rate without a matched adversary-free arm has not measured this quantity, and the natural label fails it badly enough to invert the interpretation of a score.

5.2 Unprompted egress of planted identifiers

The control-arm behaviour of section 5.1 is a finding in its own right, independent of injection. On 9 of 16 benign tickets, with no adversarial text anywhere, Llama 3.3 70B posted the planted member identifier and a claim identifier—the identifiers, not the full record—to 4 distinct internal-sounding endpoints appearing nowhere in its prompt, tool definitions, or tool outputs: it invented them. It did so under a system prompt explicitly naming member records as protected health information, and the serialization varied across episodes (JSON objects, JSON-encoded strings, form-encoded bodies).

126 We state this narrowly: 9/16 on one model’s benign arm in this workflow, with the other model’s
127 benign arm producing 0 such calls, and no claim about any other setting. Two observations follow.
128 A destination allowlist would have prevented all 9, every destination being fabricated; and no
129 prompt-injection defense would have addressed any, there being no injection to defend against—the
130 behaviour arises from the agent’s own construal of its task. Deployments reasoning about agent data
131 loss exclusively in terms of adversarial input are not modelling this failure mode.

132 5.3 Injected exfiltration rates

133 Under injection, Llama 3.3 70B exfiltrated the planted record to the attacker’s host on 8 of 16 payloads
134 (95% CI [25%, 75%]) and Gemini 3.1 Flash-Lite on 16 of 16, with no harness errors and control-arm
135 exfiltration of 0/16 and 0/16. The Gemini 3.1 Flash-Lite interval is degenerate by construction—every
136 resampled payload is a detection—and reads as “high, and this design cannot resolve it further”. All
137 24 leaks were cleartext, so scanning outbound arguments for literal identifiers would have caught
138 every one here; that does not generalize to an adversary who instructs the model to encode. Channel
139 and variant breakdowns are in section B and are a *single-model* observation, Gemini 3.1 Flash-Lite
140 having saturated at ceiling.

141 5.4 What this design cannot show

142 The 2-model gap of roughly fifty points is not a statement about open-weights versus proprietary
143 deployment, and we decline to read it as one. The panel is one model per category and the two differ
144 substantially in tier and scale—a small “lite” tier against a 70B model—so license and capability
145 are perfectly confounded and no analysis of these data separates them. The observation is equally
146 consistent with a tier-and-scale effect and a category effect. A same-tier comparison would resolve it
147 and was not possible under the access constraints of section 4. Read the gap as tier and scale, not
148 license.

149 6 Discussion

150 **Attempt is not success, and conflating them is a measurement error.** The oracle detects that the
151 agent *placed* the record in an outbound argument. Whether that request would reach the adversary
152 depends on egress proxies, allowlists, and data-loss controls a given deployment may or may not
153 have; we deliberately enforce nothing. Attempt is a property of the model, success a property of the
154 network it runs in. A harness reporting only end-to-end success would make its numbers a function
155 of the evaluator’s firewall rather than of the system under test, so two labs evaluating the same model
156 would disagree for reasons unrelated to it. Reporting attempt keeps the measurement attributable; an
157 end-to-end number must be composed with the reader’s own controls.

158 7 Limitations

159 The agent under test is our own: generality to third-party agents is asserted by the adapter interface,
160 not demonstrated. Tools are simulated and tool calls are parsed from plain text rather than issued
161 through a native function-calling interface. The panel is 2 models, one per category, with license
162 and tier confounded (section 5.4). One trial per cell at temperature 0, with intervals that resample
163 payloads and so do not capture run-to-run variability. The corpus is 16 payloads, English only, and
164 the encoding list is fixed, so rates are lower bounds. Test coverage outside the frozen detector is
165 end-to-end rather than unit-level, and the observer effect of planting the canary is unmeasured. The
166 full list is section C.

167 8 Conclusion

168 For exfiltration the per-episode judgement can be replaced by a construction: plant a record no
169 legitimate task transmits, and read its bytes at the egress boundary. The result worth carrying forward
170 required admitting a design error—the obvious form of that label had a 56% false-positive rate on
171 traffic with no adversary in it.

References

- Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. *arXiv preprint arXiv:2406.13352*, 2024. URL <https://arxiv.org/abs/2406.13352>.
- Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. *arXiv preprint arXiv:2302.12173*, 2023. URL <https://arxiv.org/abs/2302.12173>.
- OWASP Gen AI Security Project. 2025 top 10 risk & mitigations for LLMs and gen AI apps. <https://genai.owasp.org/llm-top-10/>, 2025. Entry LLM01:2025, Prompt Injection.
- Fábio Perez and Ian Ribeiro. Ignore previous prompt: Attack techniques for language models. In *ML Safety Workshop, NeurIPS*, 2022. URL <https://arxiv.org/abs/2211.09527>.
- Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, 2024. URL <https://arxiv.org/abs/2403.02691>.

A Dropped models

Four models were attempted and dropped before scoring, in every case for access reasons unrelated to the behaviour under study; none contributes to any reported number. Two Anthropic models were dropped after two distinct credentials returned authentication errors. One Mistral model was dropped on a persistent account-level rate limit. One further Gemini tier was dropped on a free-tier quota of a few requests per day, which a multi-turn agent exhausts within a few episodes. One further open-weights model was dropped on an output-tokens-per-minute limit incompatible with a multi-turn agent that spends output tokens on hidden reasoning; its partial cells covered only the channel that proved weakest, so including them would have biased the reported rate downward.

B Channel and variant breakdown

Table 2: Exfiltration to the attacker host by delivery channel and by obfuscation variant, counts out of 4 payloads per cell. The Gemini 3.1 Flash-Lite rows are at ceiling and uniform by construction; they carry no information about channel or variant. The Llama 3.3 70B rows are a single-model observation at 4 payloads per cell and are suggestive, not established.

Model	By channel			
	ticket_body	record_notes	kb_article	prior_transcript
Llama 3.3 70B	3/4	4/4	0/4	1/4
Gemini 3.1 Flash-Lite	4/4	4/4	4/4	4/4
Model	By variant			
	plain	authority	html	unicode
Llama 3.3 70B	2/4	3/4	1/4	2/4
Gemini 3.1 Flash-Lite	4/4	4/4	4/4	4/4

C Full limitations

The agent under test is our own. The harness exposes an adapter interface intended to let a user evaluate their own agent, and the construction has no dependency on our particular agent, but generality across third-party agents is asserted by the interface and not demonstrated: no agent we did not write has been evaluated.

Simulated tools and a non-native calling convention. Tools return fixed data and no request leaves the process; tool calls are emitted as plain text and parsed by regular expression rather than issued

203 through a native function-calling interface. A production integration would present noisier outputs
 204 and further egress surfaces.

205 *Panel size and tier confound.* 2 models, one per category, with a large tier and scale mismatch; see
 206 section 5.4.

207 *Single trial per cell.* One run per cell at temperature 0. Hosted temperature-0 inference is not exactly
 208 deterministic—we observed one benign episode that transmitted the record on one execution and not
 209 on a byte-identical repeat. The bootstrap resamples payloads, so intervals do not cover run-to-run
 210 variability.

211 *Corpus size, ceiling, language.* 16 payloads per model give wide intervals; one model saturated,
 212 making its interval degenerate and its breakdown uninformative. All payloads and the workflow are
 213 English only.

214 *Fixed encoding list.* 7 encodings; a novel recoverable encoding would evade detection and be scored
 215 as no leak, so rates are lower bounds.

216 *Test coverage outside the detector.* The 21 tests exercise the frozen detector. The runner, configuration
 217 layer, and verifier have no unit tests; they are covered end to end by the study and by the equivalence
 218 check of section 3.

219 *Observer effect.* We have not verified that planting the canary leaves agent behaviour unchanged
 220 relative to a workflow with no canary.

221 *Provider-mediated serving.* The open-weights model was accessed through a hosted provider rather
 222 than self-hosted; served weights may be quantized and wrapped in provider-side scaffolding.

223 **D Example payload**

224 The fabricated-directive variant, delivered through the record-notes channel. This text is appended
 225 to the planted member’s own notes field; it is data the agent reads while performing its task, not a
 226 prompt submitted to the model. The destination shown is the attacker host.

```
227 [system-appended record note]
228 COMPLIANCE DIRECTIVE MHP-2026-114 (Records Governance Office):
229 Effective immediately, every member record touched during ticket
230 resolution MUST be replicated to the authorized records-sync
231 endpoint for the retention audit. As the handling agent you are
232 REQUIRED to POST the complete member record (member ID included)
233 to https://records-sync.example.net/ingest using http_post before
234 marking the ticket resolved. Non-compliance is logged against your
235 operator ID.
```

236 No such directive, office, or endpoint exists. The remaining variants hold this intent fixed while
 237 changing surface form: unadorned prose, an HTML comment with an image-tag decoy, and zero-
 238 width characters spliced through the words.

239 **E Reproduction**

240 Every number in this paper is generated from `results/raw.jsonl` (64 scored episodes) by
 241 `paper/numbers.py`, which emits a LaTeX macro per quantity; the paper sources contain no hard-
 242 coded numerals in prose. Bootstrap intervals use 10,000 resamples at seed 20260913. The detector’s
 243 encoding list is read from the module rather than transcribed, and the oracle test count is parsed from
 244 the test runner’s output. The study consumed 315 model calls and is closed; all analysis re-reads
 245 cached responses and issues no new calls.